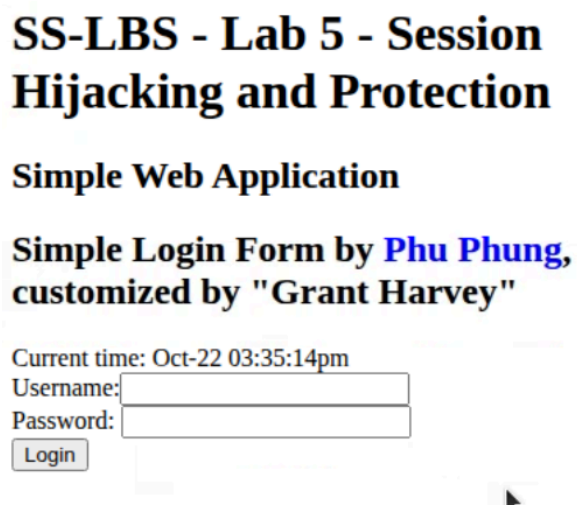
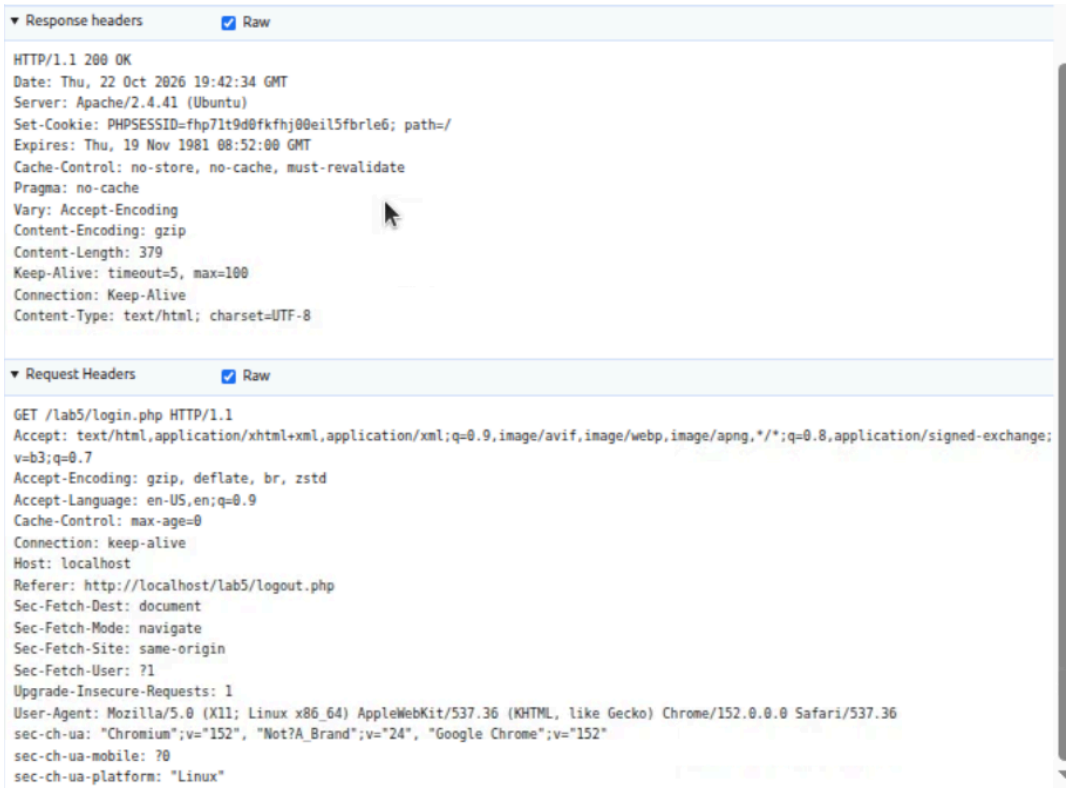
Grant Harvey
harveyg3@udayton.edu
CPS 474 - Software and language based security
Dr Phu Phung
Bitbucket link: https://bitbucket.org/granthsrvey/ss-lbs-harveyg3/src/main/

# Lab 05

**Task 01 - Understanding Session Management**

a.

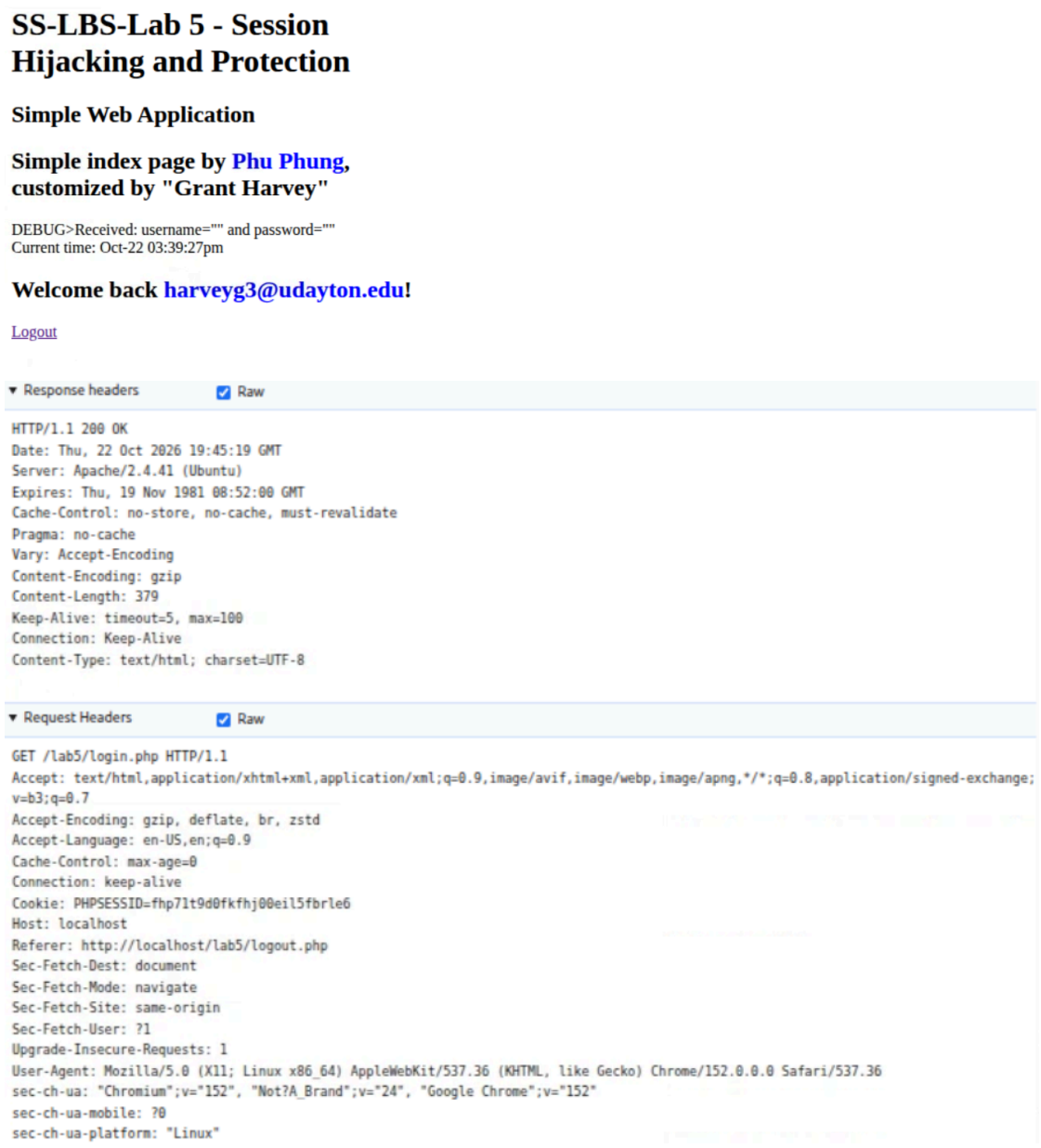





i. In the HTTP Request there is no cookie value because it hasn't been set yet
ii. In the HTTP Response the cookie value is being set:

```
Set-Cookie: PHPSESSID=fhp71t9d0fkfhj00eil5fbrle6; path=/
```

b.



## SS-LBS-Lab 5 - Session Hijacking and Protection

### Simple Web Application

### Simple index page by Phu Phung, customized by "Grant Harvey"

DEBUG>Received: username="" and password=""
Current time: Oct-22 03:39:27pm

### Welcome back harveyg3@udayton.edu!

Logout

▼ Response headers  Raw

```
HTTP/1.1 200 OK
Date: Thu, 22 Oct 2026 19:45:19 GMT
Server: Apache/2.4.41 (Ubuntu)
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 379
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8
```

▼ Request Headers  Raw

```
GET /lab5/login.php HTTP/1.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;
v=b3;q=0.7
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: en-US,en;q=0.9
Cache-Control: max-age=0
Connection: keep-alive
Cookie: PHPSESSID=fhp71t9d0fkfhj00eil5fbrle6
Host: localhost
Referer: http://localhost/lab5/logout.php
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/152.0.0.0 Safari/537.36
sec-ch-ua: "Chromium";v="152", "Not?A_Brand";v="24", "Google Chrome";v="152"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Linux"
```

i. In the HTTP Request we have the same cookie value as in a.ii

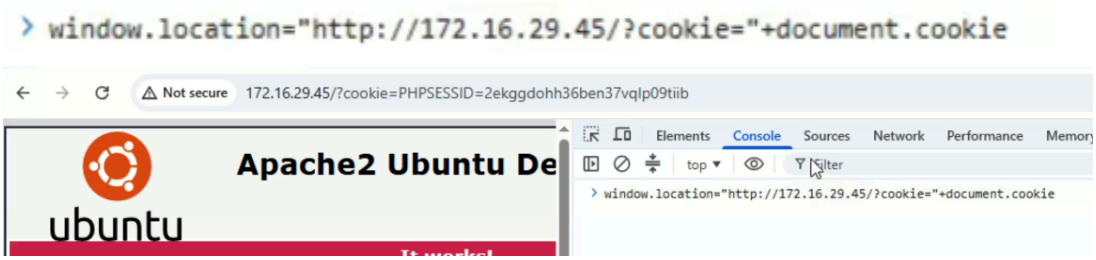
```
Cookie: PHPSESSID=fhp71t9d0fkfhj00eil5fbrle6
```

ii. In the HTTP Response we have no cookie value since the cookie has already been set

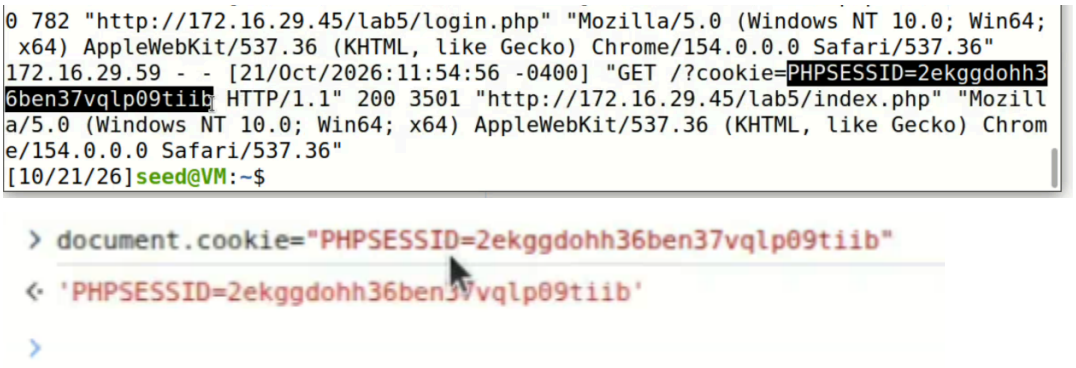
## Task 2 - Session Hijacking Attack

a.

i.




ii.







The video demonstration of these steps is also attached in the submission of this assignment

b. The attack we did in part a is called a Session Hijacking Attack, it's when you steal a cookie from another user and use it yourself. In this case we stole the cookie of a user who logged in and used it ourself, you can see it doesn't include all the data like the username and password, but it does include the login state.



## Task 3 - Fix the session hijacking vulnerability

a.

```
19 19         if (mockchecklogin($username,$password)){
20 20                 $_SESSION["logged"]=TRUE;
21 21                 $_SESSION["username"] = $username;
   22 +               $_SESSION["browser"] = $_SERVER["HTTP_USER_AGENT"];
22 23                 $welcome = "Welcome "; //not previously logged-in
23 24         }else{//failed
24 25                 redirect_login('Invalid username/password');
   ↓ ↑   @@ -28,6 +29,10 @@  (Shift + click to expand all lines)
28 29               if ($_SESSION["logged"]!=TRUE) {
29 30               redirect_login('You have not logged in. Please login first!');
30 31               }
   32 +             if ($_SESSION["browser"] != $_SERVER["HTTP_USER_AGENT"]) {
   33 +                   echo "Session hijacking is detected!";
   34 +                   die();
   35 +             }
31 36         }
32 37         //the main business logic implementation of the page
33 38         echo "Current time: " . date("M-d h:i:sa") . "\n";
```

There were a few other changes made in the whole commit, but these 2 were the ones necessary to fix the session hijacking.

b. I did the same exact thing as before but when I ran the document.cookie command in the console and refreshed it, I was setting a specific cookie and stopped the application.

```
e/154.0.0.0 Safari/537.36"
172.16.41.71 - - [22/Oct/2026:16:15:40 -0400] "GET /icons/ubuntu-logo.png HTTP/1
.1" 200 3623 "http://172.16.41.90/?cookie=PHPSESSID=0kh3mld3qp9k05g14lr8ct376l"
"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko
) Chrome/154.0.0.0 Safari/537.36"
[10/22/26]seed@VM:~$
```

# SS-LBS-Lab 5 - Session Hijacking and Protection

## Simple Web Application

## Simple index page by Phu Phung, customized by "Grant Harvey"

DEBUG>Received: username="" and password=""
Session hijacking is detected!